

OPS.1.1.8 Infrastructure as Code, Pipelines und DevOps-Prozesse

1 Beschreibung

1.1 Einleitung

Moderne IT-Betriebs- und Entwicklungsmodelle nutzen zunehmend DevOps-Praktiken, um die Bereitstellung von Anwendungen und Diensten zu automatisieren. Kernelemente dieser Vorgehensweise sind der Einsatz von CI/CD-Pipelines (Continuous Integration / Continuous Delivery), die Verwaltung von Infrastruktur als Code (Infrastructure as Code, IaC) und die Nutzung von Versionsverwaltungssystemen als zentrale, maßgebliche Datenquelle ("Single Source of Truth"). Durch diese Automatisierung von Betriebs- und Entwicklungsprozessen entstehen spezifische Angriffsvektoren. Eine Kompromittierung der CI/CD-Pipeline oder der Versionsverwaltung kann es Angreifern ermöglichen, Schadcode in produktive Anwendungen einzuschleusen, Zugangsdaten zu entwenden oder die Infrastruktur unbemerkt zu manipulieren. Fehlerhafter IaC kann zudem zur massenhaften Bereitstellung verwundbarer Infrastrukturen führen.

1.2 Zielsetzung

Ziel dieses Bausteins ist der Schutz der Integrität, Vertraulichkeit und Verfügbarkeit in hochautomatisierten DevOps-Umgebungen. Er formuliert Anforderungen, um DevOps-Prozesse und die zugehörigen Werkzeugketten (Versionsverwaltung, CI/CD-Tools, IaC-Frameworks) abzusichern. Sicherheitsmechanismen sollen tief in den automatisierten Lebenszyklus integriert werden ("DevSecOps"), um den Missbrauch von Pipelines zu verhindern und fehlerhafte Auslieferungen frühzeitig zu erkennen.

1.3 Abgrenzung und Modellierung

Der Baustein OPS.1.1.8 ist auf den Informationsverbund einmal anzuwenden, sofern DevOps-Prozesse, Infrastructure as Code oder CI/CD-Pipelines eingesetzt werden.

Dieser Baustein behandelt nicht die spezifischen Anforderungen an die sichere Softwareentwicklung auf Ebene des Quellcodes; diese werden im Baustein CON.8 Software-Entwicklung adressiert. Werden Webanwendungen entwickelt oder betrieben, sind ergänzend die Bausteine CON.10 Entwicklung von Webanwendungen sowie APP.3.1 Webanwendungen und Webservices heranzuziehen. Grundlegende Anforderungen an die Absicherung von Server-Betriebssystemen oder Cloud-Ressourcen, auf denen die Pipelines betrieben werden oder in die provisioniert wird, finden sich in den entsprechenden Infrastruktur-Bausteinen (z. B. SYS.1.1 Allgemeiner Server, OPS.2.2 Cloud-Nutzung).

2 Gefährdungslage

Für DevOps-Prozesse und zugehörige Werkzeugketten sind folgende spezifische Gefährdungen von besonderer Bedeutung:

Kompromittierung der CI/CD-Pipeline

Angreifer verschaffen sich unautorisierten Zugriff auf die Konfiguration oder die Laufzeitumgebung der CI/CD-Pipeline (z. B. Jenkins, GitLab CI, GitHub Actions). Dadurch können Build-Prozesse manipuliert werden, um Schadcode einzuschleusen, fertige Artefakte zu verändern oder hinterlegte Zugangsdaten zu kompromittieren.

Unsicherer oder fehlerhafter Infrastructure as Code (IaC)

IaC-Skripte (z. B. Terraform, Ansible) können Konfigurationsfehler enthalten, die zur Bereitstellung unsicherer Infrastruktur führen. Typische Folgen sind offene Firewall-Regeln, öffentlich zugängliche Cloud-Speicherdienste oder die Verwendung schwacher kryptografischer Einstellungen. Durch die automatisierte Skalierbarkeit werden solche Fehler systemweit ausgerollt.

Verlust der Integrität und Vertraulichkeit von IaC-Zustandsdateien

IaC-Werkzeuge verwalten den aktuellen Zustand der Infrastruktur häufig in sogenannten State Files. Diese Dateien enthalten hochsensible Informationen, teils im Klartext, darunter Passwörter, Datenbank-Zugänge oder private Schlüssel. Ein unbefugter Zugriff auf diese Dateien führt zu einem unmittelbaren Vertraulichkeitsverlust und ermöglicht Folgeangriffe.

Kompromittierung von Zugangsdaten in der Versionsverwaltung

Sensible Zugangsdaten wie Passwörter, API-Schlüssel oder private Zertifikate werden oft versehentlich oder aus Bequemlichkeit direkt im Code in Versionsverwaltungssystemen (z. B. Git) hinterlegt. Diese sind dann für alle Leseberechtigten des Repositories einsehbar und können leicht missbraucht werden.

Einschleusung von Schadcode über kompromittierte Abhängigkeiten (Supply Chain Attack)

CI/CD-Pipelines laden häufig automatisch externe Softwarebibliotheken, Basis-Images für Container oder andere Abhängigkeiten aus öffentlichen Quellen herunter. Sind diese Quellen kompromittiert oder enthalten die Abhängigkeiten Schwachstellen, wird der Schadcode unbemerkt in die eigenen Anwendungen integriert.

Missbrauch durch unzureichende Funktionstrennung

Verfügen Mitarbeitende über weitreichende Berechtigungen, die es ihnen erlauben, Code zu schreiben, zu genehmigen und ohne weitere Kontrollen produktiv zu setzen, fehlt das

Vier-Augen-Prinzip. Dies erhöht das Risiko von unbeabsichtigten Fehlern sowie von vorsätzlicher Sabotage oder Manipulation.

Unzureichende Kontrolle und Protokollierung automatisierter Prozesse

Aufgrund der hohen Geschwindigkeit von DevOps-Prozessen entfallen oft manuelle Kontrollschritte. Werden Änderungen an der Infrastruktur oder Anwendungen ohne ausreichende automatisierte Prüfungen und ohne detaillierte Protokollierung produktiv gesetzt, erschwert dies die Nachvollziehbarkeit von Aktionen und die Aufklärung von Sicherheitsvorfällen erheblich.

3 Anforderungen

Im Folgenden sind die spezifischen Anforderungen des Bausteins OPS.1.1.8 aufgeführt. Grundsätzlich ist der IT-Betrieb für die Erfüllung der Anforderungen zuständig. Abweichungen werden in den entsprechenden Anforderungen gesondert genannt.

Zuständigkeiten	Rollen
Grundsätzlich zuständig	IT-Betrieb
Weitere Zuständigkeiten	Informationssicherheitsbeauftragter (ISB), Fachverantwortliche, Entwickler

3.1 Basis-Anforderungen

Die folgenden Anforderungen MÜSSEN vorrangig erfüllt werden.

OPS.1.1.8.A1 Richtlinie für sichere DevOps-Prozesse (B) [ISB]

Es MUSS eine Richtlinie für die sichere Gestaltung und den sicheren Betrieb von CI/CD-Pipelines, IaC und DevOps-Prozessen existieren. Diese MUSS grundlegende Sicherheitsvorgaben, Verantwortlichkeiten, zulässige Werkzeuge sowie Freigabeverfahren für Deployments festlegen.

OPS.1.1.8.A2 Absicherung der Versionsverwaltung (B)

Das zentrale Versionsverwaltungssystem MUSS gegen unbefugten Zugriff abgesichert sein. Es MUSS ein striktes Berechtigungskonzept umgesetzt sein, das den Lese- und Schreibzugriff auf Code-Repositories regelt. Alle Änderungen am Code MÜSSEN nachvollziehbar einer individuellen Person zugeordnet werden können.

OPS.1.1.8.A3 Grundlegender Schutz von Zugangsdaten (Secrets) (B)

[Entwickler]

Zugangsdaten (wie Passwörter, API-Schlüssel oder private Schlüssel) DÜRFEN NICHT unverschlüsselt im Quellcode oder in Repositories der Versionsverwaltung gespeichert werden. Entwickler MÜSSEN bezüglich des korrekten Umgangs mit kryptografischem Material und Zugangsdaten regelmäßig sensibilisiert werden.

OPS.1.1.8.A4 Rudimentäre Zugriffskontrolle für CI/CD-Werkzeuge (B)

Der Zugriff auf die Administrations- und Konfigurationsoberflächen der CI/CD-Werkzeuge MUSS auf einen definierten, minimal erforderlichen Personenkreis beschränkt sein. Es MUSS restriktiv geregelt sein, wer Pipelines anlegen, ausführen und deren Konfiguration ändern darf.

OPS.1.1.8.A5 Protokollierung der Pipeline-Aktivitäten (B)

Alle sicherheitsrelevanten Aktivitäten innerhalb der CI/CD-Pipeline MÜSSEN protokolliert werden. Dies MUSS mindestens das Starten und Fehlschlagen von Builds, Änderungen an der Pipeline-Konfiguration sowie durchgeführte Deployments umfassen.

OPS.1.1.8.A17 Sichere Authentisierung an der Versionsverwaltung (B)

Für den administrativen und schreibenden Zugriff auf das Versionsverwaltungssystem sowie auf CI/CD-Steuerungskomponenten MUSS eine sichere Authentisierung eingesetzt werden.

3.2 Standard-Anforderungen

Gemeinsam mit den Basis-Anforderungen entsprechen die folgenden Anforderungen dem Stand der Technik bei normalem Schutzbedarf. Sie SOLLTEN grundsätzlich erfüllt werden.

OPS.1.1.8.A18 Konzeption der Pipeline-Architektur (S)

Die Architektur der CI/CD-Pipeline und der IaC-Umgebung SOLLTE vor deren Aufbau detailliert konzipiert werden. In der Konzeption SOLLTEN Netzübergänge, Vertrauensgrenzen zwischen Komponenten sowie die erforderlichen Integrationspunkte für Sicherheitswerkzeuge definiert werden.

OPS.1.1.8.A6 Einsatz eines zentralen Secrets Managements (S)

Zugangsdaten, die von der CI/CD-Pipeline oder von IaC-Skripten benötigt werden, SOLLTEN zentral und kryptografisch abgesichert über ein dediziertes Secrets-Management-System verwaltet werden. Die Pipeline SOLLTE sich zur Laufzeit an diesem System authentisieren, um ausschließlich die für den jeweiligen Lauf benötigten Secrets abzurufen.

OPS.1.1.8.A7 Sicherung von Code-Änderungen durch Branch-Protection und Reviews (S)

Für produktiv relevante Zweige (Branches) im Versionsverwaltungssystem SOLLTEN

Schutzmechanismen (Branch Protection) aktiviert werden. Änderungen SOLLTEN ausschließlich über Pull- oder Merge-Requests in den Hauptzweig übernommen werden. Dabei SOLLTE eine Freigabe durch mindestens eine weitere Person (Vier-Augen-Prinzip) zwingend gefordert werden.

OPS.1.1.8.A8 Integration von automatisierten Sicherheitsprüfungen (SAST/SCA) (S)

In die CI/CD-Pipeline SOLLTEN automatisierte Werkzeuge zur Sicherheitsanalyse integriert werden. Dies SOLLTE mindestens eine statische Code-Analyse (Static Application Security Testing, SAST) sowie eine Analyse der eingebundenen Abhängigkeiten auf bekannte Schwachstellen (Software Composition Analysis, SCA) umfassen. Die Pipeline SOLLTE so konfiguriert sein, dass Builds bei Funden von kritischen Schwachstellen fehlschlagen.

OPS.1.1.8.A9 Absicherung von Build-Artefakten und Container-Images (S)

Erzeugte Build-Artefakte und Container-Images SOLLTEN in einem zentralen, zugriffsgeschützten Artefakt-Repository gespeichert werden. Container-Images SOLLTEN vor dem Deployment automatisiert auf bekannte Schwachstellen gescannt werden.

OPS.1.1.8.A10 Statische Analyse von Infrastructure as Code (IaC) (S)

Infrastructure as Code SOLLTE vor der Ausführung durch spezialisierte Werkzeuge statisch auf Sicherheitsfehlkonfigurationen und die Einhaltung interner Richtlinien überprüft werden (Policy as Code).

OPS.1.1.8.A11 Detailliertes Rollen- und Rechtekonzept (S)

Es SOLLTE ein detailliertes Rollen- und Rechtekonzept für die CI/CD-Pipeline nach dem Prinzip der geringsten Rechte (Least Privilege) umgesetzt werden. Es SOLLTE technisch und organisatorisch sichergestellt sein, dass das Schreiben von Code, das Genehmigen von Builds und das Durchführen von Deployments funktional getrennt sind (Segregation of Duties).

OPS.1.1.8.A19 Absicherung von IaC-Zustandsdateien (State Files) (S)

Werden IaC-Zustandsdateien verwendet (z. B. Terraform State), SOLLTEN diese an einem zentralen, versionierten und stark zugriffsgeschützten Ort abgelegt werden. Die Zustandsdateien SOLLTEN im Ruhezustand (Data at Rest) verschlüsselt sein.

OPS.1.1.8.A20 Trennung von Entwicklungs-, Test- und Produktionsumgebungen (S)

Die Umgebungen für Entwicklung, automatisierte Tests und den produktiven Betrieb SOLLTEN netztechnisch und logisch streng voneinander getrennt werden. CI/CD-Pipelines SOLLTEN über

dedizierte Dienstkonten mit minimalen Rechten für die jeweilige Zielumgebung verfügen.

3.3 Anforderungen bei erhöhtem Schutzbedarf

Die folgenden Anforderungen sind exemplarisch und bei erhöhtem Schutzbedarf zu berücksichtigen; die konkrete Festlegung erfolgt im Rahmen einer Risikoanalyse. Der Schutzziel-Bezug ist am Ende jeder Anforderung in Klammern angegeben (C = Vertraulichkeit, I = Integrität, A = Verfügbarkeit).

OPS.1.1.8.A21 Planung der Absicherung der Software-Lieferkette (H) [Planer]

Bei erhöhtem Schutzbedarf SOLLTE in der Planungsphase ein Konzept zur umfassenden Absicherung der Software-Lieferkette (Supply Chain Security) erstellt werden, das den Integritätsschutz von extern bezogenen Komponenten regelt. (I)

OPS.1.1.8.A12 Härtung und Isolation der Pipeline-Umgebung (H)

Die Laufzeitumgebung der CI/CD-Pipeline (Build-Agents oder Runner) SOLLTE systemtechnisch gehärtet und isoliert sein. Build-Jobs SOLLTEN in flüchtigen (ephemeren) Umgebungen ausgeführt werden, die nach jeder Ausführung zerstört werden. Der Netzwerkzugriff der Build-Agents auf interne Ressourcen und das Internet SOLLTE restriktiv gefiltert werden. (C, I, A)

OPS.1.1.8.A13 Erstellung und Verifizierung von Software-Stücklisten (SBOM) (H)

Für jedes Build-Artefakt SOLLTE automatisiert eine maschinenlesbare Software-Stückliste (Software Bill of Materials, SBOM) in einem anerkannten Standardformat (z. B. CycloneDX, SPDX) generiert werden. Diese SOLLTE archiviert und laufend gegen neue Schwachstellendatenbanken abgeglichen werden. (I, A)

OPS.1.1.8.A14 Integration fortgeschrittener Sicherheitsanalysen (DAST/IAST) (H)

Zusätzlich zu statischen Analysen SOLLTEN fortgeschrittene dynamische Sicherheitsanalysen (Dynamic Application Security Testing, DAST) oder interaktive Analysen (Interactive Application Security Testing, IAST) in dedizierten Testumgebungen als obligatorischer Bestandteil der Pipeline durchgeführt werden. (C, I)

OPS.1.1.8.A15 Kryptografische Signierung von Code-Commits und Artefakten (H) [Entwickler]

Commits im Versionsverwaltungssystem SOLLTEN von den Entwicklern kryptografisch signiert werden. Alle durch die Pipeline erzeugten Build-Artefakte und Images SOLLTEN ebenfalls

automatisiert signiert werden. Vor einem Deployment SOLLTE die Signatur zwingend verifiziert werden. (I)

OPS.1.1.8.A16 Prinzip der unveränderlichen Infrastruktur (Immutable Infrastructure) (H)

Die durch IaC bereitgestellte Infrastruktur SOLLTE als unveränderlich behandelt werden. Anpassungen an der Laufzeitumgebung SOLLTEN ausschließlich über Aktualisierungen im IaC-Code erfolgen. Manuelle Konfigurationsänderungen auf produktiven Systemen SOLLTEN technisch unterbunden werden. (I, A)

OPS.1.1.8.A22 Kryptografische Fixierung von Abhängigkeiten (Hash-Pinning) (H) [Entwickler]

Externe Bibliotheken, Pakete und Basis-Images SOLLTEN in den Konfigurationsdateien nicht nur auf eine bestimmte Versionsnummer beschränkt, sondern über kryptografische Prüfsummen (Hashes) eindeutig fixiert werden, um Manipulationen an den Quell-Repositories (z. B. Dependency Confusion) abzuwehren. (I, A)

4 Weiterführende Informationen

4.1 Wissenswertes

Weiterführende Informationen zur Absicherung von DevOps-Prozessen und der Software-Lieferkette finden sich in folgenden Dokumenten:

- **BSI TR-03183:** Technische Richtlinie zur Cyberresilienz von Software und Software-Ökosystemen
- **OWASP:** Top 10 CI/CD Security Risks (Open Worldwide Application Security Project)
- **CIS:** Software Supply Chain Security Guide (Center for Internet Security)
- **NIST:** Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities (NIST SP 800-218)

Kreuzreferenztable zu elementaren Gefährdungen

Die folgenden elementaren Gefährdungen sind für den Baustein OPS.1.1.8 von Bedeutung:

- G 0.14 Ausspähen von Informationen (Spionage)
- G 0.18 Fehlplanung oder fehlende Anpassung
- G 0.19 Offenlegung schützenswerter Informationen
- G 0.20 Informationen oder Produkte aus unzuverlässiger Quelle
- G 0.21 Manipulation von Hard- oder Software
- G 0.22 Manipulation von Informationen
- G 0.28 Software-Schwachstellen oder -Fehler
- G 0.31 Fehlerhafte Nutzung oder Administration von Geräten und Systemen
- G 0.32 Missbrauch von Berechtigungen

- G 0.39 Schadprogramme
- G 0.45 Datenverlust

Anforderung	G 0.14	G 0.18	G 0.19	G 0.20	G 0.21	G 0.22	G 0.28	G 0.31	G 0.32	G 0.39	G 0.45
OP S.1.1 .8.A 1 (B)		X						X			
OP S.1.1 .8.A 2 (B)	X				X	X			X		
OP S.1.1 .8.A 3 (B)	X		X					X	X		
OP S.1.1 .8.A 4 (B)	X				X	X			X		
OP S.1.1 .8.A 5 (B)					X			X	X		
OP S.1.1 .8.A 17 (B)	X				X	X			X		

OP S.1.1 .8.A 18 (S)		X									
OP S.1.1 .8.A 6 (S)	X		X						X		
OP S.1.1 .8.A 7 (S)					X	X		X	X	X	
OP S.1.1 .8.A 8 (S)				X			X			X	
OP S.1.1 .8.A 9 (S)				X	X	X	X			X	
OP S.1.1 .8.A 10 (S)							X	X			
OP S.1.1 .8.A 11 (S)	X				X			X	X		
OP	X		X		X	X		X	X		X

S.1.1 .8.A 19 (S)											
OP S.1.1 .8.A 20 (S)					X	X		X		X	
OP S.1.1 .8.A 21 (H)		X		X	X						
OP S.1.1 .8.A 12 (H)	X				X	X			X	X	
OP S.1.1 .8.A 13 (H)				X			X				
OP S.1.1 .8.A 14 (H)							X			X	
OP S.1.1 .8.A 15 (H)				X	X	X					
OP S.1.1					X	X		X		X	

.8.A 16 (H)											
OP S.1.1 .8.A 22 (H)				X	X	X				X	